

Informe Ejecutivo RGPD

Fecha y hora
2026-05-26 07:07 CEST

Nivel de riesgo
ALTO

Cobertura
AEPD - EDPB - ICO - CNIL - CE

Apertura de jornada con foco en novedades regulatorias, sanciones, brechas y obligaciones prioritarias para empresas espanolas.

Hechos confirmados La AEPD mantiene actualizado a 22 de mayo de 2026 su cuadro de mando de brechas; el informe de abril registra 527 notificaciones, 451 del sector privado, 261 accesos no autorizados, 144 casos de phishing y 117 incidentes de ransomware.	Interpretacion analitica El riesgo regulatorio inmediato para empresas espanolas se concentra en seguridad operativa, transparencia real antes de captar datos, gestion de encargados y evidencia de evaluaciones de impacto en procesos con IA o alto riesgo.	Recomendacion automatica Priorizar esta semana una revision de brechas a 72 horas, avisos previos a la recogida, contratos con proveedores criticos y DPIA para tratamientos con IA, scoring, vigilancia o categorias especiales.
--	--	---

Dashboard ejecutivo

Brechas notificadas en abril de 2026 ante AEPD	527	451 del sector privado	Accesos no autorizados dentro de esas brechas	261	144 phishing y ransomware
Brechas con impacto transfronterizo	81	dato AEPD abril 2026	Autoridades europeas en accion coordinada 2026	25	foco EDPB en transparencia

Novedades principales

El Tribunal Supremo eleva el liston desde la fase previa de recogida de datos

Que ha ocurrido La AEPD explico en abril de 2026, a partir de la STS 1590/2026, que el tratamiento de datos personales comienza ya con las actuaciones dirigidas a solicitarlos, y no solo despues de recibirlos.	Fuente oficial o verificable AEPD - Analisis sobre STS 1590/2026
Por que importa Sube el riesgo en formularios, procesos comerciales, RRHH, onboarding y captacion digital: la base juridica, la informacion y la minimizacion deben estar resueltas antes de pedir el dato.	Impacto para empresas espanolas Las empresas espanolas no deberian tratar la fase de solicitud como un paso neutro. Si piden mas datos de los necesarios o informan tarde, el incumplimiento nace antes de guardar el registro.
Accion recomendada Revisar formularios, scripts comerciales, procesos de seleccion y alta de clientes para asegurar informacion por capas, legitimacion y minimizacion desde el primer contacto.	

La AEPD confirma un mes de abril con presion alta en brechas y afectacion privada

Que ha ocurrido El informe mensual de la AEPD sobre abril de 2026 recoge 527 notificaciones. Destacan 451 notificaciones del sector privado, 261 accesos no autorizados, 144 incidentes de phishing, 117 casos de ransomware y 81 brechas con implicaciones transfronterizas.	Fuente oficial o verificable AEPD - Informe de brechas abril 2026
Por que importa La combinacion de intrusiones, phishing y ransomware refuerza que el riesgo ya no es solo de disponibilidad. La confidencialidad y la obligacion de comunicar a afectados siguen plenamente vigentes.	Impacto para empresas espanolas Las empresas espanolas con proveedores cloud, CRM, ERPs expuestos, VPN o accesos remotos deben asumir que una brecha de un tercero puede activar obligaciones de notificacion y dano reputacional propio.
Accion recomendada Probar el playbook de 72 horas, asegurar MFA, revisar accesos remotos, logging, contencion y mensajes preparados para autoridad, clientes, empleados y afectados.	

Europa mantiene un enfoque sancionador duro en seguridad, retencion y notificacion

Que ha ocurrido La ICO multo el 7 de mayo de 2026 a South Staffordshire con GBP 963.900 tras una brecha que afecto a 633.887 personas. La CNIL mantiene en 2026 sanciones de EUR 27 millones y EUR 15 millones contra dos operadores por seguridad insuficiente y notificacion deficiente de una brecha.	Fuente oficial o verificable ICO y CNIL - enforcement 2026
Por que importa Los reguladores siguen castigando fallos basicos: autenticacion remota debil, deteccion deficiente, retencion excesiva y mala gestion de la comunicacion a afectados.	Impacto para empresas espanolas Telecom, utilities, salud, retail y servicios con grandes volumenenes de datos deben tratar la seguridad, la retencion y la comunicacion de brechas como temas de comite, no solo de IT.
Accion recomendada Lanzar una revision express de articulos 32 y 34 RGPD: VPN, MFA, retencion, deteccion, borrado historico y criterios documentados para comunicar a afectados.	

Riesgos para empresas

Brechas

Presion alta en ransomware, phishing, accesos no autorizados y propagacion desde proveedores o cuentas remotas.

Transparencia

Riesgo al pedir datos sin base juridica clara, sin capas informativas utiles o con textos poco comprensibles.

Proveedores

Encargados con acceso amplio, controles debiles, subencargados poco visibles y ausencia de pruebas de seguridad.

ARSOPL

Respuestas lentas o poco defendibles en acceso, supresion, oposicion, portabilidad y limitacion del tratamiento.

Transferencias

Falta de mapa de flujos, SCC actualizadas y evaluaciones de transferencia en SaaS globales o soporte off-shore.

IA con datos personales

Necesidad de DPIA, minimizacion, control del entrenamiento, revisiones humanas y alfabetizacion interna.

Acciones recomendadas

- 1 Activar una revision de 10 dias del protocolo de brechas con simulacro de 72 horas y decision tree para AEPD y afectados.
- 2 Actualizar formularios y puntos de captura para que la informacion y la base juridica existan antes de s
- 3 Ado el E aval
- 4 Auditar a los encargados criticos: MFA, logs, subencargados, ubicaciones, tiempos de deteccion, derecho de auditoria y soporte en incidentes.
- 5 Purgar datos legacy y revisar politicas de retencion, bloqueo y borrado con especial foco en historicos comerciales y credenciales antiguas.

Oportunidad para MMarco Seguridad

- 1 Auditoria RGPD focalizada en brechas, transparencia y evidencia de cumplimiento.
- 1 Revision de clausulas y anexos con proveedores, subencargados v transferencias internacionales.

El EDPB lanzo el 19 de marzo de 2026 una accion coordinada en 25 autoridades sobre transparencia e informacion y adopto el 14 de abril de 2026 una plantilla comun de DPIA. Para empresas espanolas, esto refuerza la necesidad de trazabilidad documental en IA y tratamientos de alto riesgo.

transparencia, derechos ARSOPL y uso responsable de IA.

- 1 Revision de retencion y purga para CRM, expedientes heredados y repositorios compartidos.

Fuentes verificables

AEPD - En que momento comienza legalmente un tratamiento de datos personales https://www.aepd.es/prensa-y-comunicacion/blog/en-que-momento-comienza-legalmente-un-tratamiento-de-datos-personales	2026-04
AEPD - Notificaciones de brechas de datos personales a la AEPD https://www.aepd.es/derechos-y-deberes/cumple-tus-deberes/medidas-de-cumplimiento/brechas-de-datos-personales-notificacion/notificaciones-de-brechas-de-datos-personales	2026-05-22
AEPD - Informe de notificaciones de brechas durante abril de 2026 https://www.aepd.es/documento/informe-brechas-abril-2026.pdf	2026-05
EDPB - CEF 2026 sobre transparencia e informacion https://www.edpb.europa.eu/news/news/2026/cef-2026-edpb-launches-coordinated-enforcement-action-transparency-and-information_en	2026-03-19
EDPB - Plantilla DPIA https://www.edpb.europa.eu/news/news/2026/enhancing-compliance-and-consistency-edpb-ad-opts-dpia-template_en	2026-04-14
ICO - South Staffordshire Plc and South Staffordshire Water Plc https://ico.org.uk/action-weve-taken/enforcement/2026/05/south-staffordshire-plc-and-south-staffordshire-water-plc/	2026-05-07
CNIL - Data breach: FREE MOBILE and FREE fined EUR 42 million https://www.cnil.fr/en/sanction-free-2026	2026-01-14
Commission europeenne - Ten years of the GDPR: your data, your rights https://commission.europa.eu/news-and-media/news/ten-years-gdpr-your-data-your-rights-2026-05-22_en	2026-05-22

Informe generado automaticamente con apoyo de IA. Tiene finalidad informativa y no constituye asesoramiento juridico, auditoria RGPD ni dictamen legal profesional. Requiere validacion profesional antes de tomar decisiones juridicas o regulatorias.